SEGSI

CIBERSEGURANÇA E ADMINISTRAÇÃO DE SISTEMAS

DCR

Active Directory?

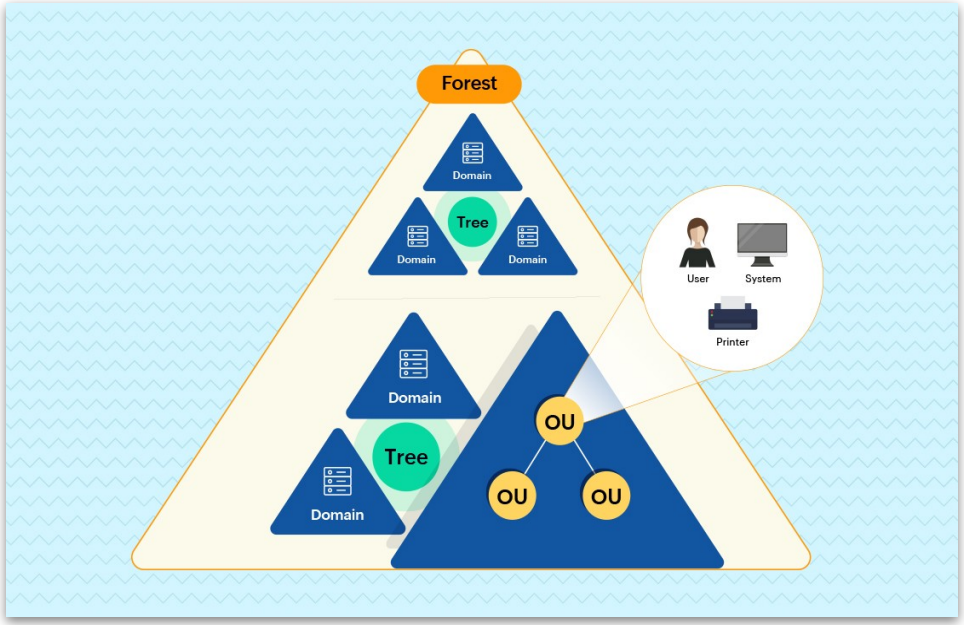
- Active Directory is a system that interconnect objects in an enterprise;
- It is often preferred due to the seamless integration with already established technologies and environments;
- Provides security controls and elasticity to adapt to the business itself;
- I also provides a central instance to manage domains and distribute responsibilities to the necessary entities.

Why is it a great front to attack

- Active Directory is a system of interconnected objects;
- Vulnerability scanners tend to look only to vulnerabilities and not misconfigurations (Nessus for instance);
- Security companies tend to perform vulnerability assessments and do not input the necessary time (or effort) in auditing these systems, leaving a huge gap for knowledgeable attackers to exploit;
- It is VERY fun!

How it is organized

- Active Directory starts with a Forest;
- In that forest you can have multiple domains;
- Those domains may have permissions to interconnect with others; so such Forests using “Trusts”;
- On those domains you have your users, groups, and computer;
- And everything is an object.



https://blogs.manageengine.com

How it is organized (2)

- **Users** can be added to **groups**;
- A **group** can also be added to a **group** (nested groups);
- A **group** is a collection of **users**, **groups**, and sometimes **computers**;
- A **group** is also an abstraction so we manage a group and not individual users.

How it is organized (3)

- Computers can be divided in Domain Controllers, Servers, and Workstations;
- Domain Controllers are servers that control the domain (well..);
  - The compromise of a Domain Controller is the demise of the whole domain;
- Servers are machines that provide a service and have a “Role” in the Active Directory;
- Workstations are terminal clients.

Group Policies

- Group Policies are delivered to Domain Controllers, Servers and Users;
- They **control configurations and preferences**;
- A **group policy** will **overwrite configurations** on the machine to comply with organization standards;
- They too are objects in the active directory;
  - Management permissions can be set;
  - Filters can be set to deliver to the necessary resources only;
- Often a baseline is made to guarantee compliance of the environment.

Permissions

In active directory permissions are given by DACLS - https://networkencyclopedia.com/discretionary-access-control-list-dacl

- **DACLS** are essentially comprised of **ACLs** with **ACEs**;
- **Permissions don’t only comprise of read, write, execute**. Active Directory has several special permissions;
- Permissions can be added to every object, inclusive the Forest object, GPOs, Users, Groups, Computers;
- Often maketh to work, not to be secure ☺

Create your environment

If you want to follow up the demonstration Download the ISO provided.
We will install two Virtual Machines:

- Domain Controller
- WorkStation

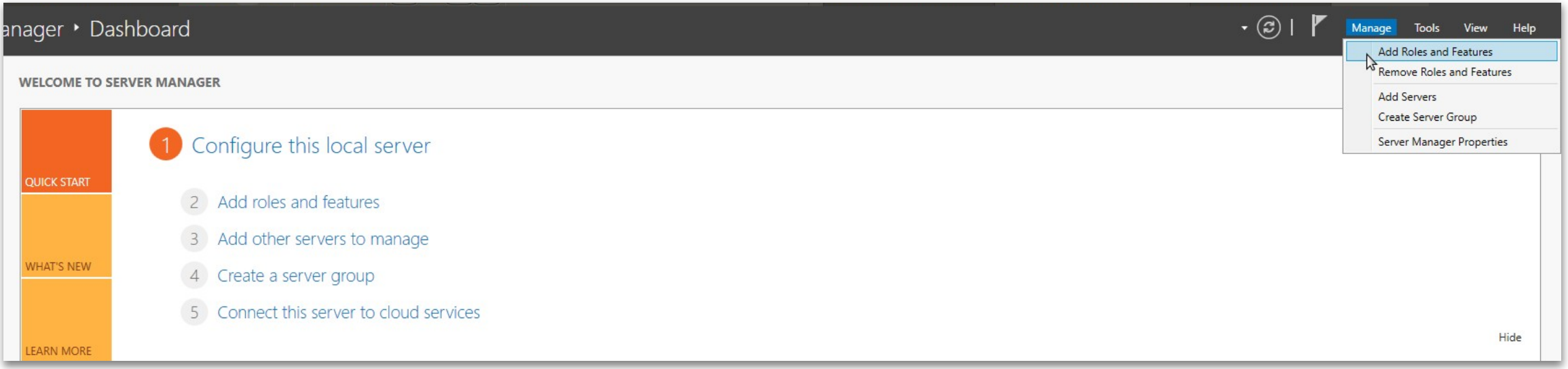
Create your environment

Lets promote the Domain Controller:

- Set the Administrator Password, otherwise the installation will not move forward;
- Change the assigned IP address to a fixed one;
- Choose a domain name;
- Choose to create a new Forest;
- Install Everything;
- Click Promote and wait for the server reboot.

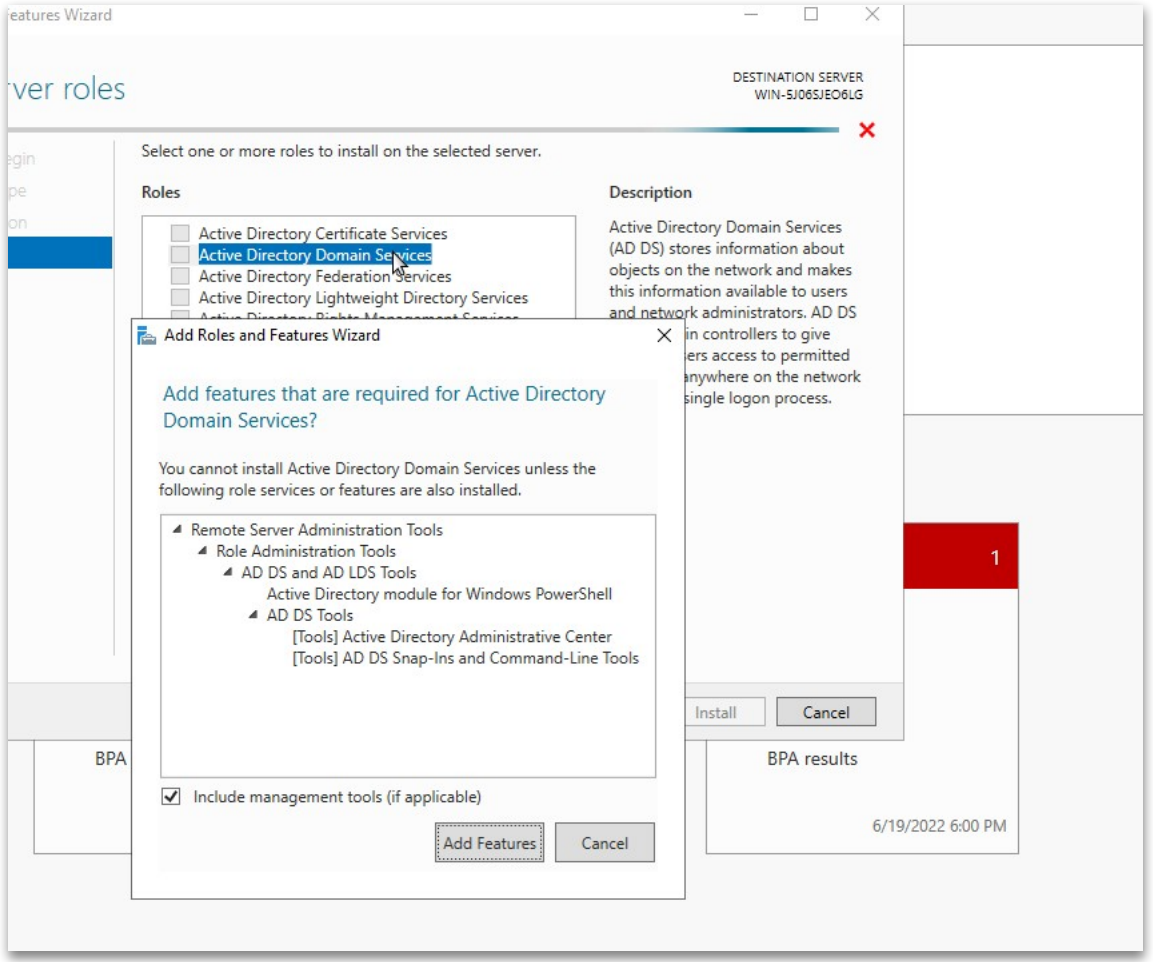
Create your environment

In the **Server Manager** program click on **Manage**, and follow to **Add Roles and Features**



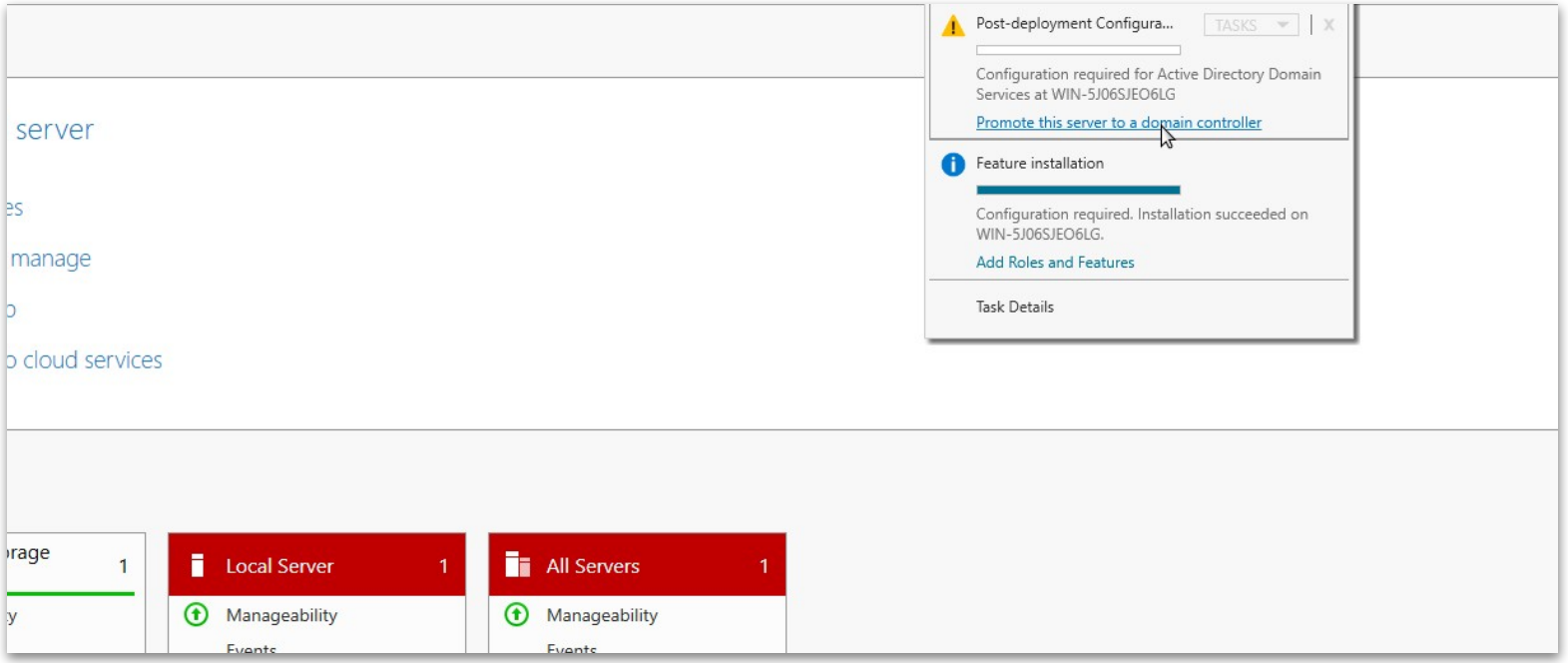
Create your environment

In the **Server Manager** program click on **Manage**, and follow to **Add Roles and Features**.



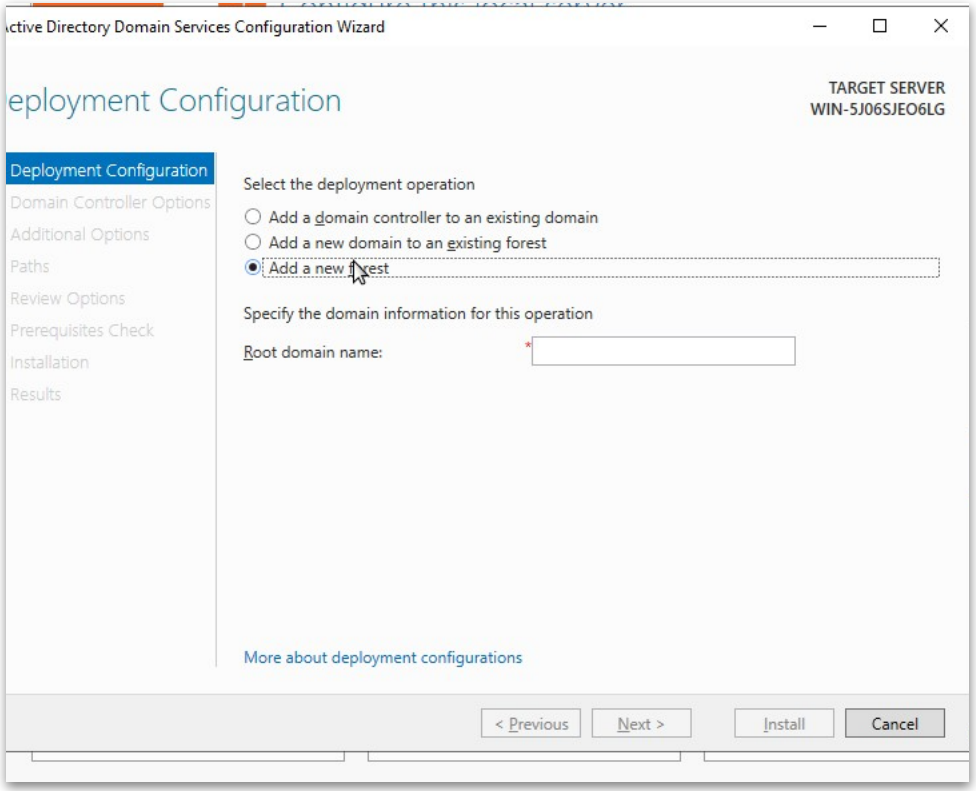
Create your environment

After it installs all the components click on the flag in the **Server Manager** application and choose **promote this server to domain controller**.



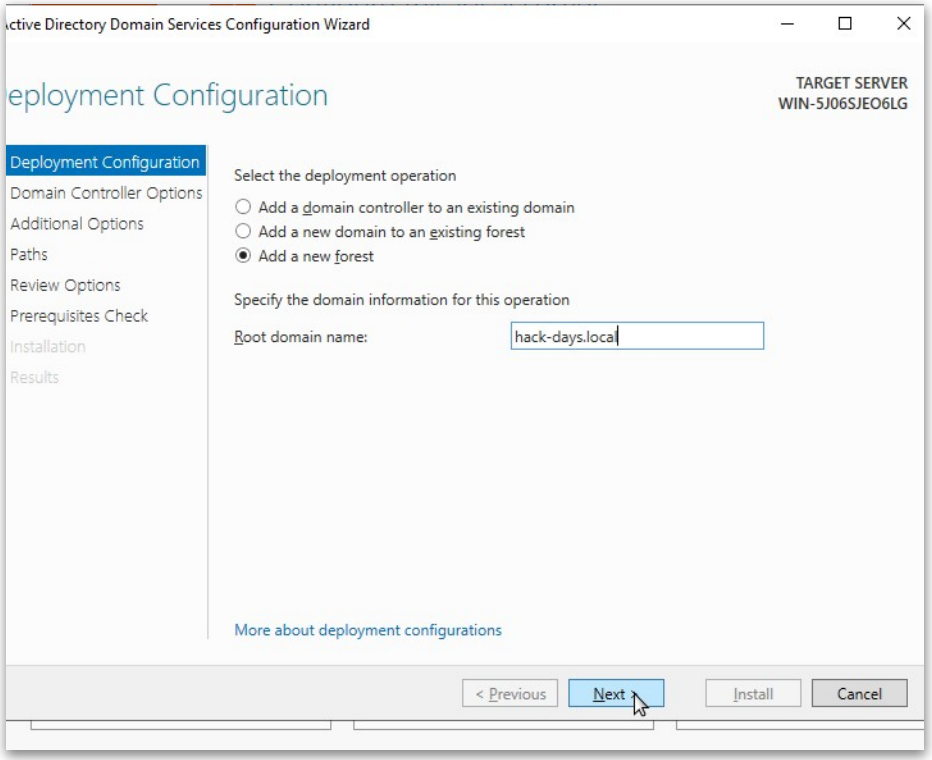
Create your environment

Select **Add a new forest** and choose a domain name (i.e. **hack-days.local**).
Note, **.local** is important to avoid clashing with public domains.



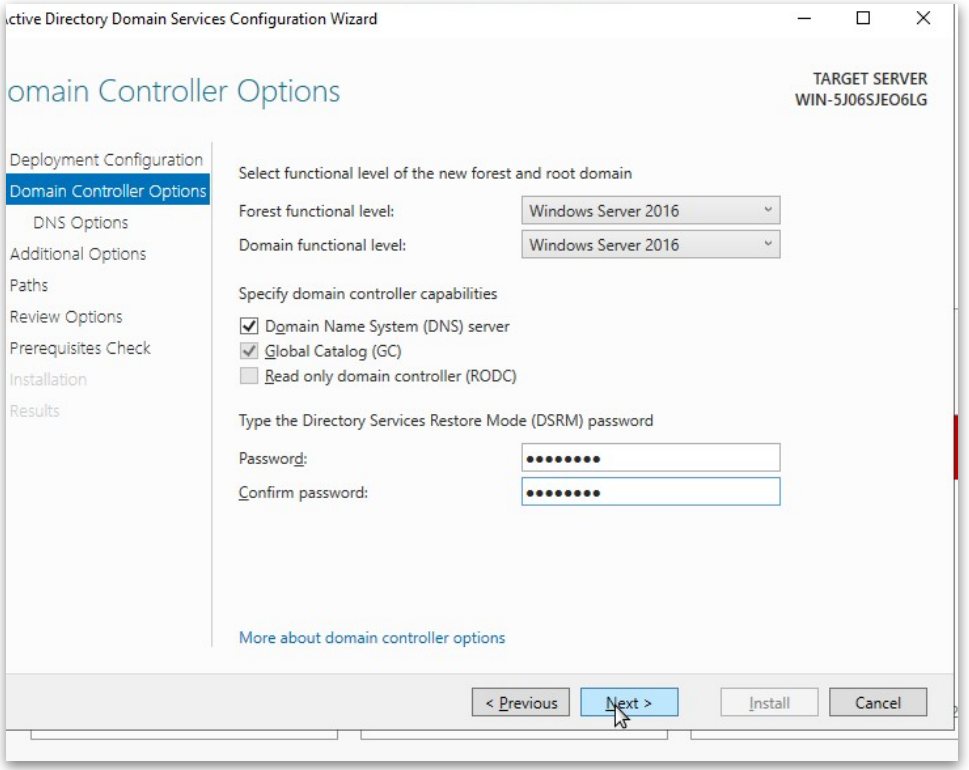
Create your environment

Select **Add a new forest** and choose a domain name (i.e. **hack-days.local**).
Note, **.local** is important to avoid clashing with public domains.



Create your environment

After clicking **Next**, more information is required. For all passwords I will choose the same value to simplify the presentation.

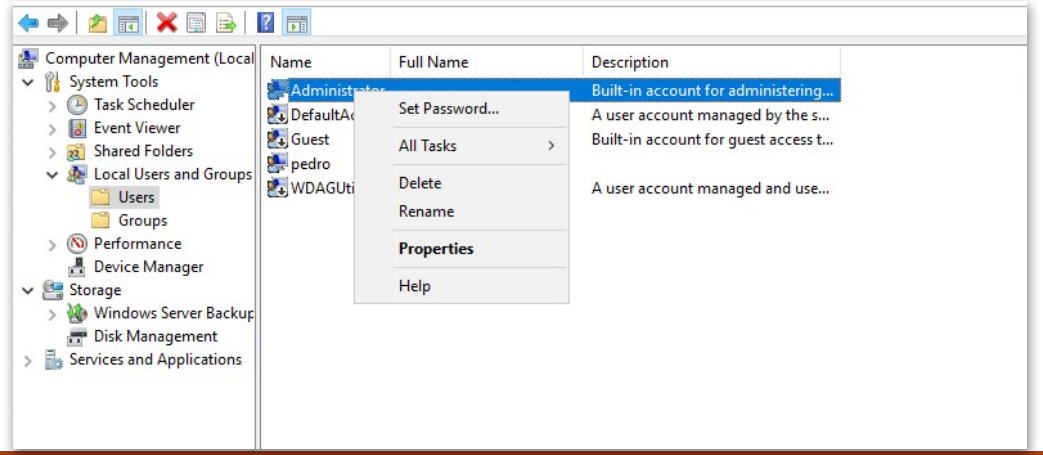


Create your environment

Note: If you install your server by the use of automatic scripts such as what VMware provides, your **Administrator** account has no password and you won't be able to promote the server to DC.

To fix this problem click with the right mouse button on the **Startup Menu** and choose **Computer Management**.

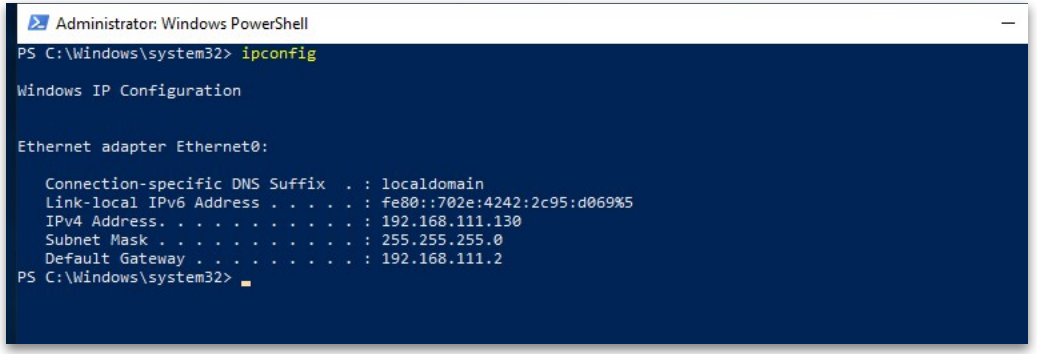
On that console navigate through **Computer Management → System Tools → Local users and Groups → Users**. Click with the right mouse button on the **Administrator** account and choose **Set Password**.
You should now be able to promote your server!



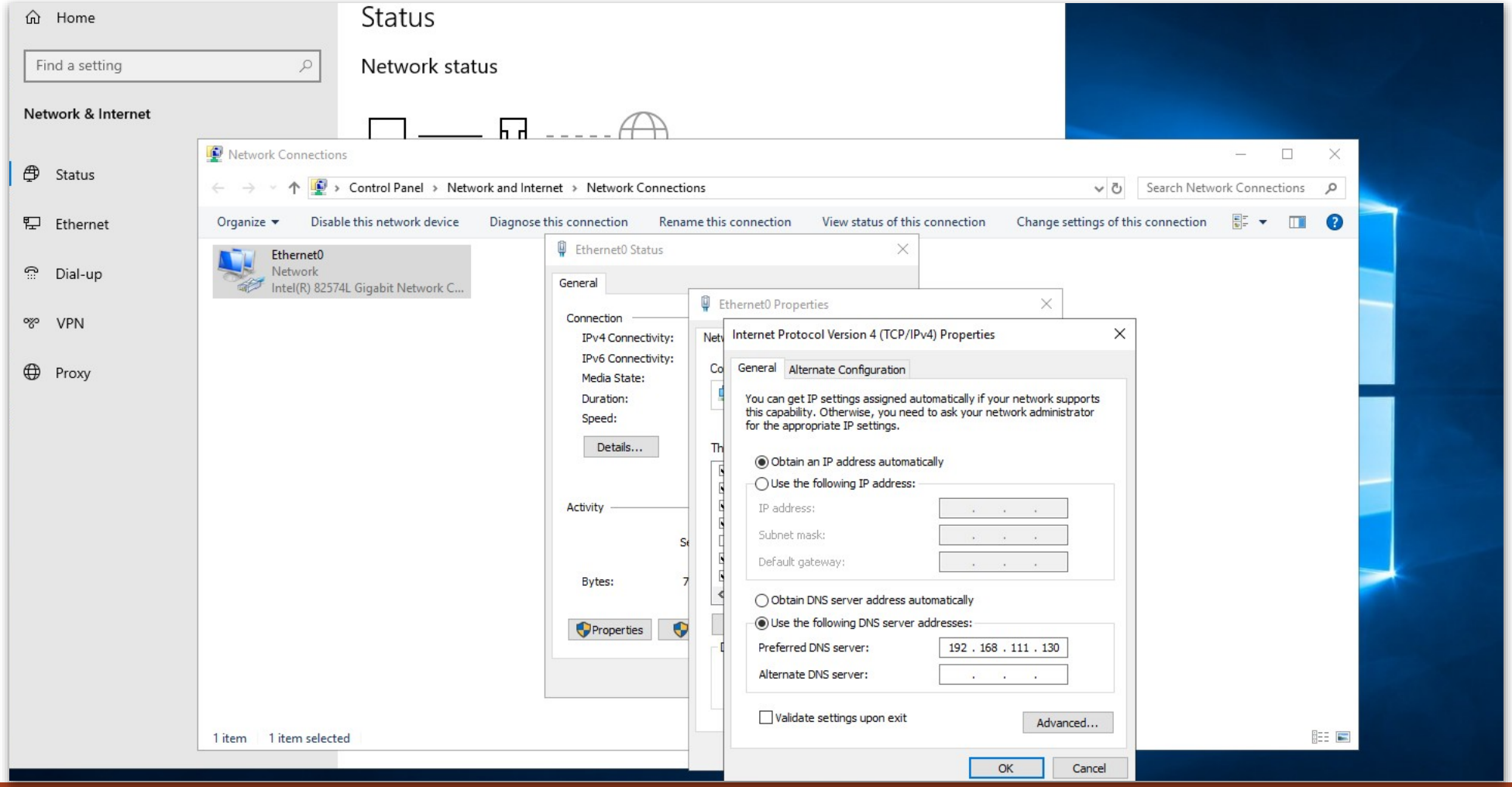
Create your environment

By default, every account can add up to **10 Workstations** to the **Domain**. This can become handy when attacking a domain. Having a Domain-Joined computer with Administrative privileges can help you explore the vectors we'll be seeing.
To add a Workstation/Server to the domain you need to set the DNS Server of the desired machine to the Domain Controller.

Go to your DC and use **ipconfig** and a command on a powershell console to get your IP address.
Take that IP and set your network adapter DNS resolver to it.

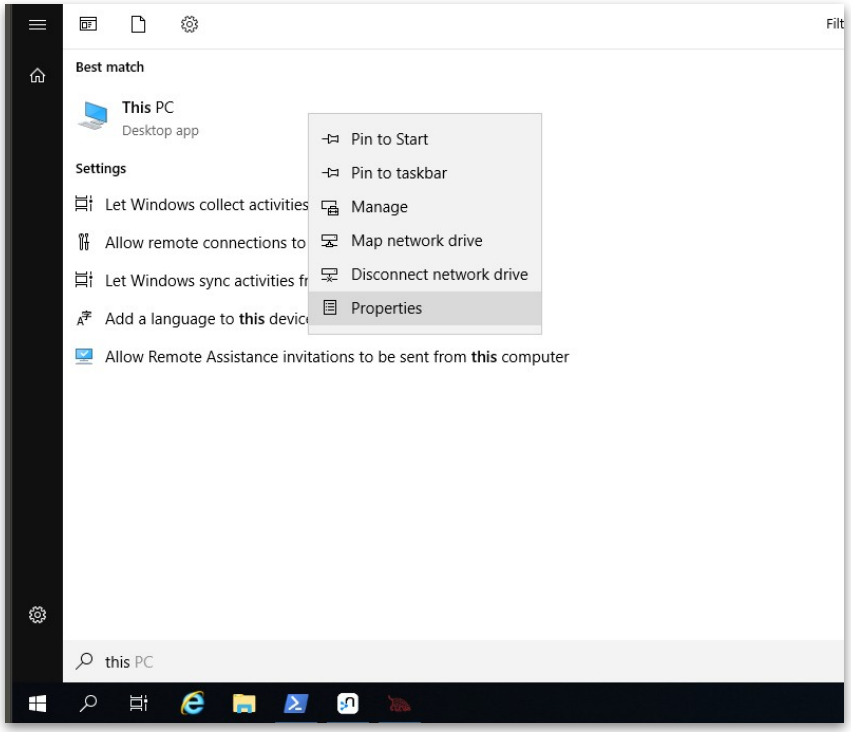


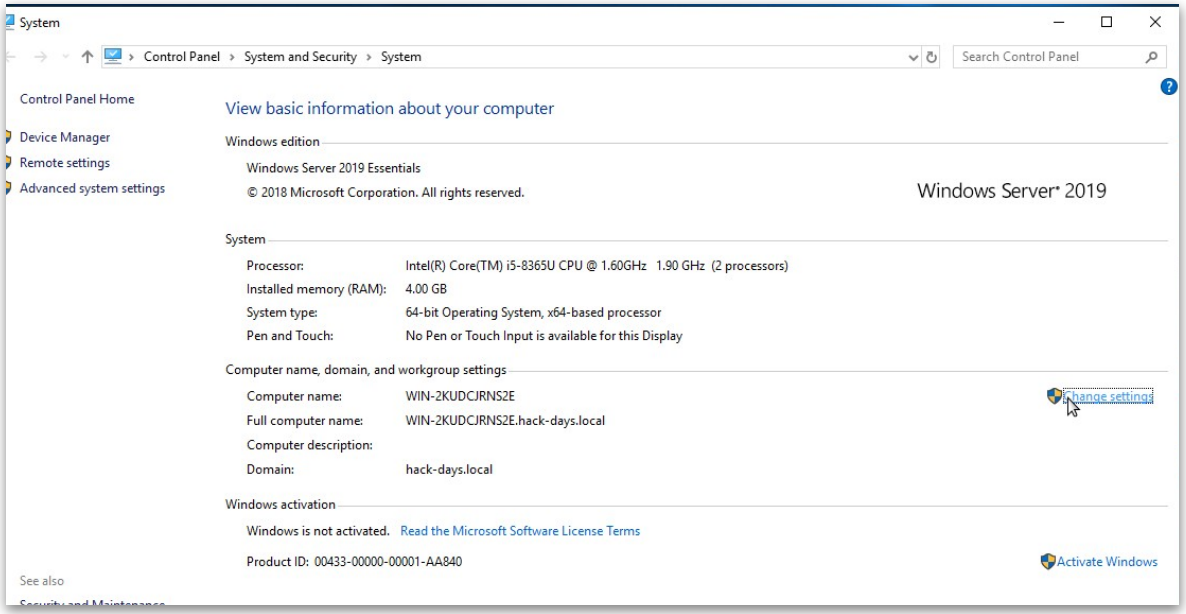
Create your environment



Create your environment

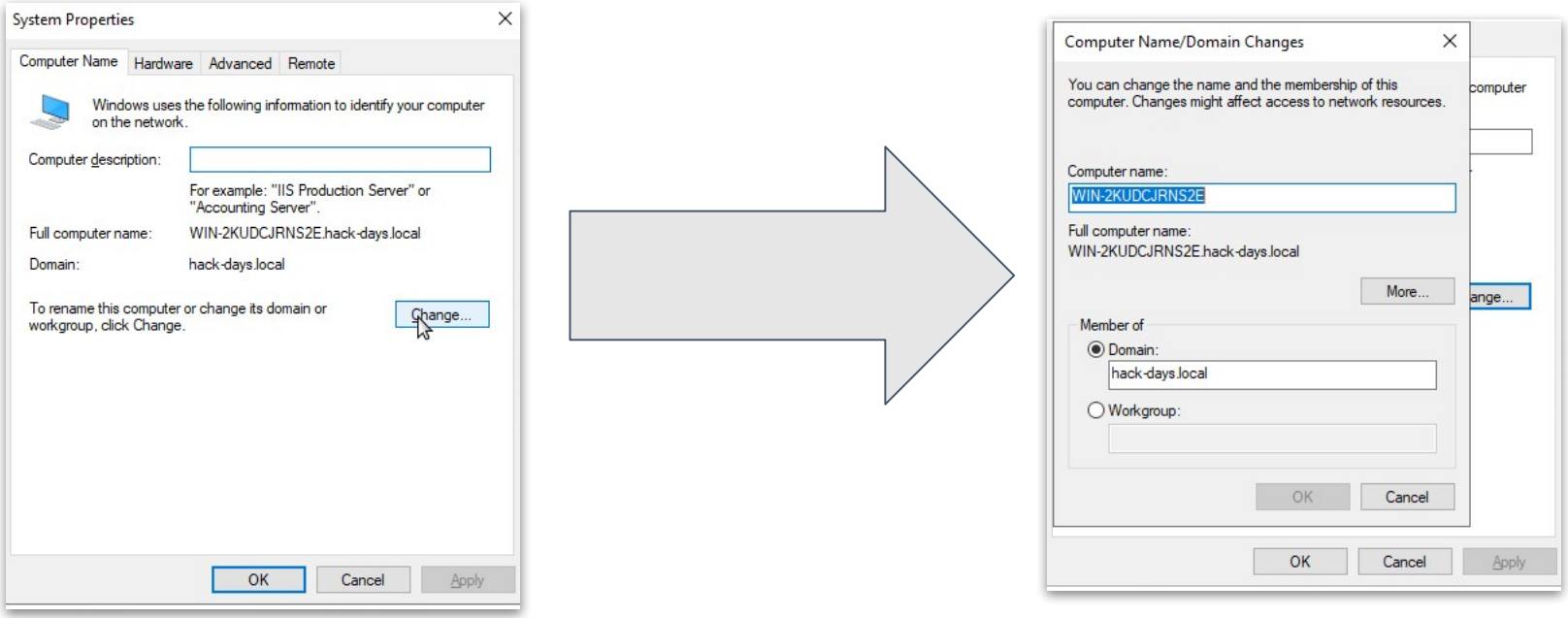
Select the startup menu and type **This PC**. Right Click on it and choose Properties. On the recently open screen look for the **Computer name, domain, and Workgroup settings** and click on **Change settings.**





Create your environment

On the opened Windows click **Change**.
Fill everything with your newly created domain. After that it will ask the DC to resolve the domain and ask you for a password to join. Just use your Administrator credential and you will join the computer to the domain.



Create your environment

Let's Create some GPOs:

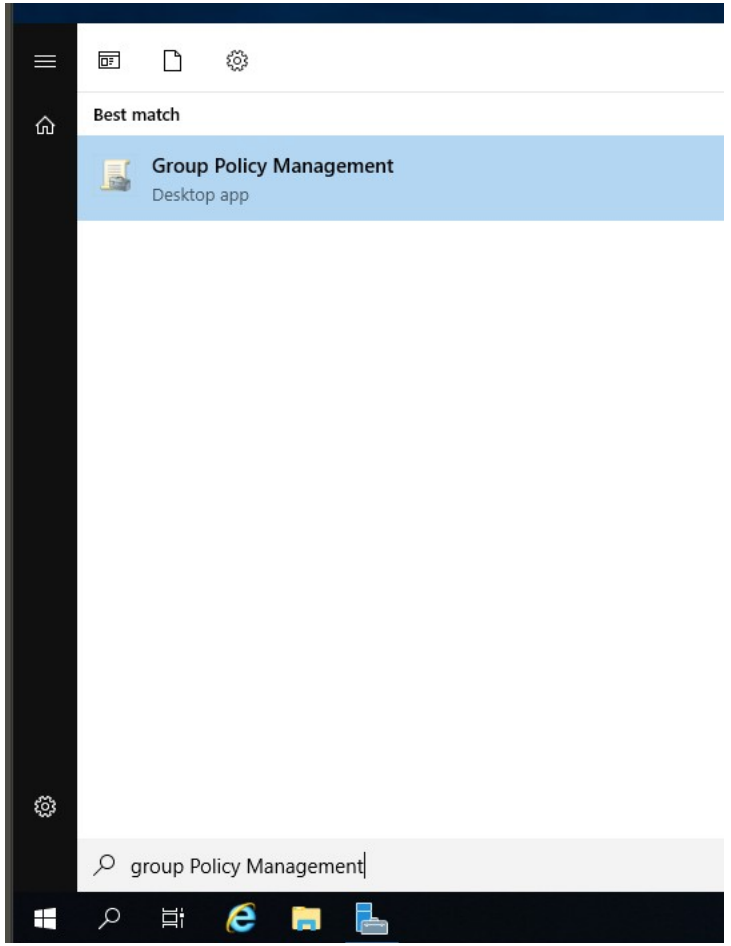
- Disable Firewall;
- Disable AV;

Remember to use **gpupdate /force** to force the policy to be updated (or let some time pass).

Create your environment

Since we are using some offensive tactics, we need to disable some Windows features to focus on the main issues. To do that we will be editing some GPOs. On the **DC** type **Group Policy Management.**

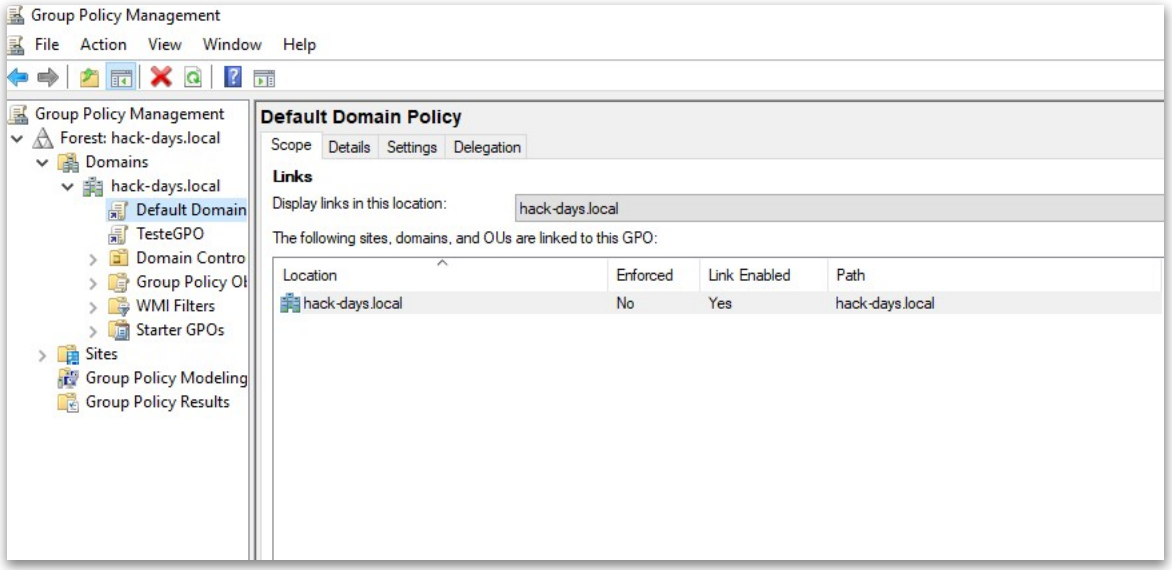
You should now see a screen similar to the second image. By default there are two GPOs in every domain: 1 Default for Servers and WorkStations and another for Domain Controllers. **Be sure to change both!**



Create your environment

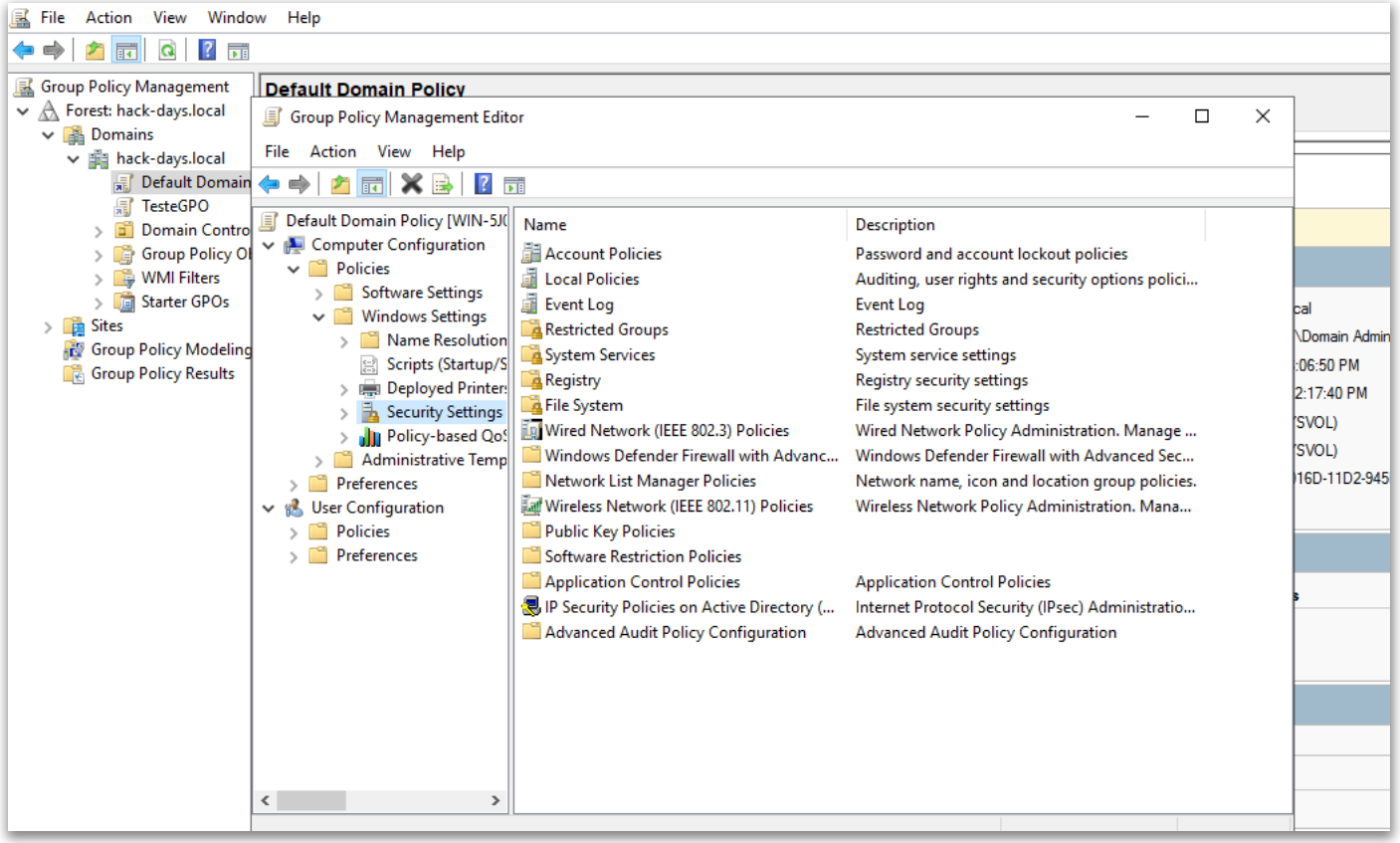
Since we are using some offensive tactics, we need to disable some Windows features to focus on the main issues. To do that we will be editing some GPOs. On the **DC** type **Group Policy Management.**

You should now see a screen similar to the second image. By default there are two GPOs in every domain: 1 Default for Servers and WorkStations and another for Domain Controllers. **Be sure to change both!**



Create your environment

Right-click on the **Default Domain Policy** and choose **Edit**.



BloodHound - Collectors

- **Collectors** are tools that will perform queries to Active Directory
- You can pass them the credentials you found together with the necessary domain name and DC IP and it will query it (if you are on a Domain Joined machine it will gather this information for you);

There are several methods of collection, some will be more “opsec” safe than others (timing might also be of some concern);

- If you use the collection method **‘All’**, the collector will also contact servers in the Active Directory:
    - Because there are local groups where you can locally give permission to users.

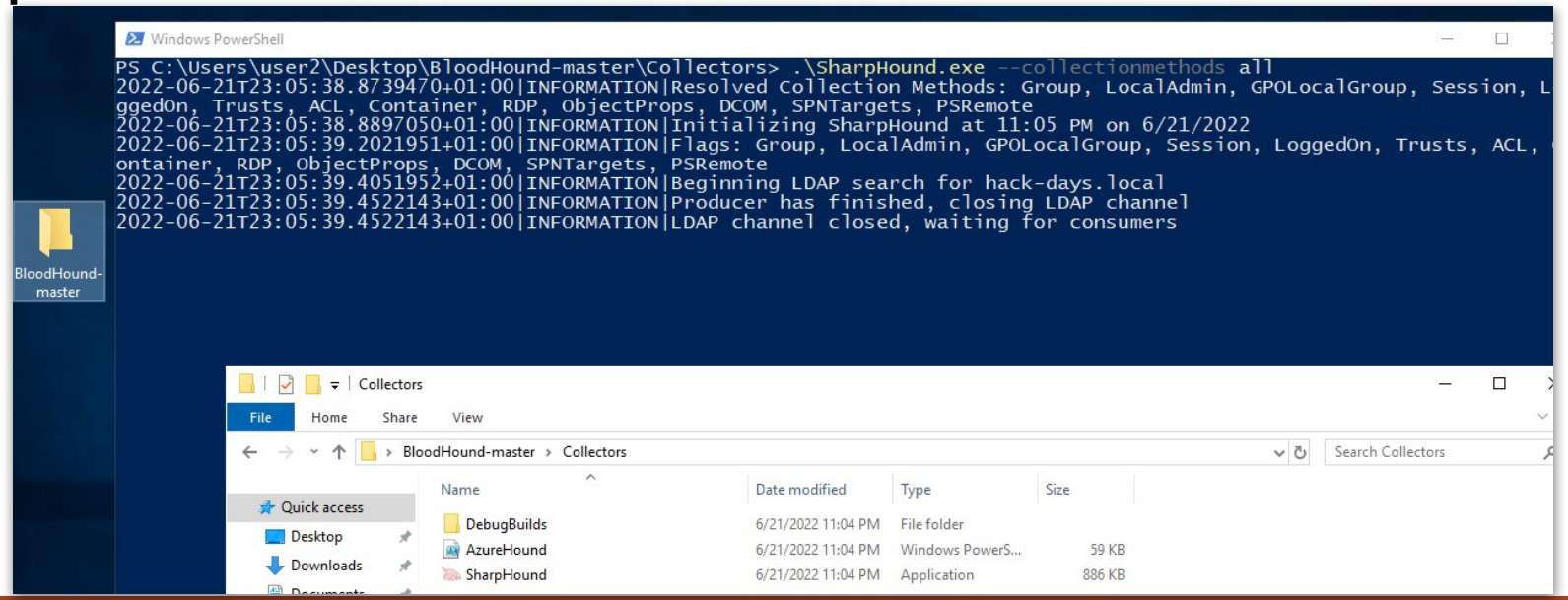
BloodHound – Collectors - Example

Download **BloodHound** into the **Workstation** using:

- **iwr ‘https://github.com/BloodHoundAD/BloodHound/archive/refs/heads/master.zip’ -O bloodhound.zip**

Extract it and navigate to the **Collectors** folder and run the **SharpHound** tool as such:

SharpHound.exe --collectionmethods all

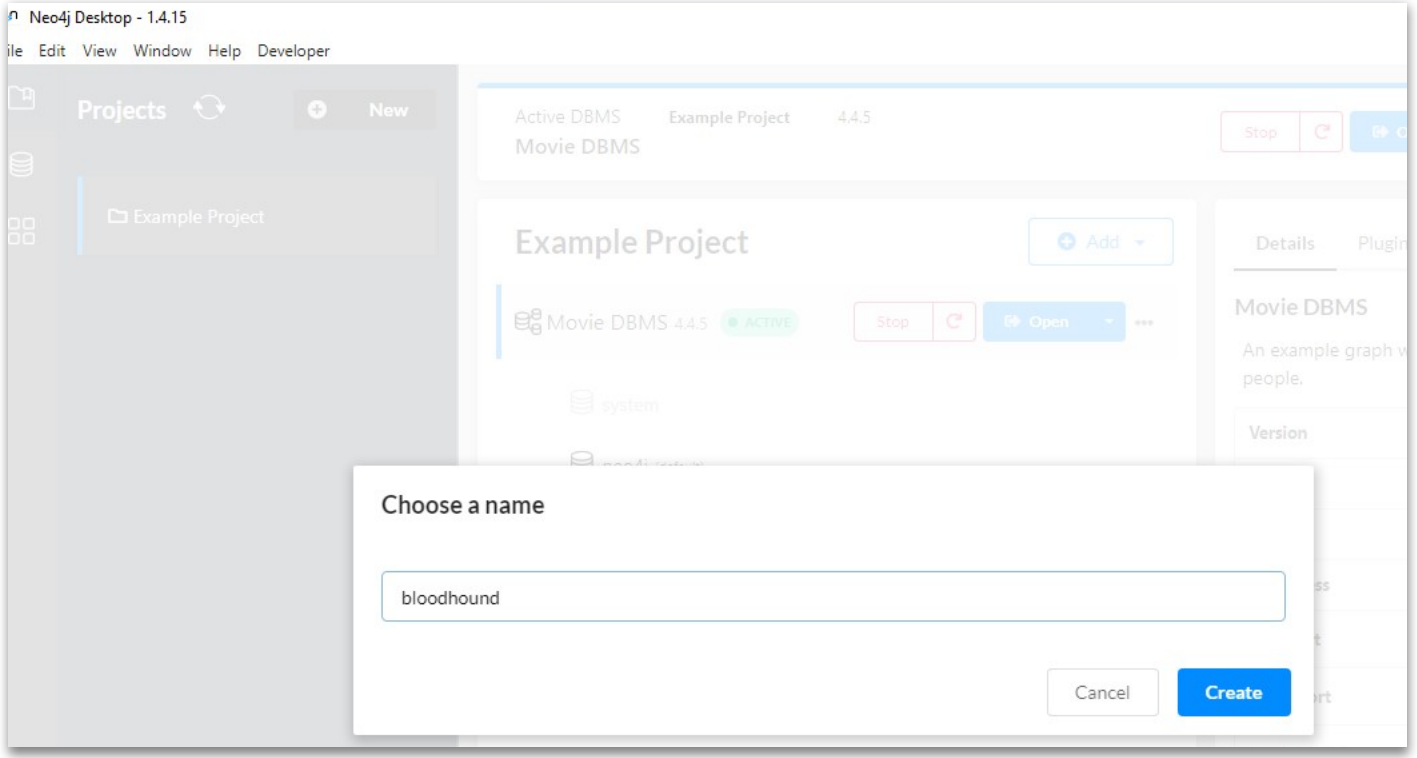


BloodHound – Neo4J

- When the collector is done, **you will have a zip file;**
- Next you should import it to **BloodHound** itself. BloodHound Interface uses Neo4J database and will interpret with the discovered edges and vertices and trace paths of exploitation;
- Download it from the official Website and install it:
    - iwr ‘https://dist.neo4j.org/neo4j-desktop/win-offline/Neo4j%20Desktop%20Setup%201.4.15.exe’ -O neo4jDesktop.exe

BloodHound – Neo4J

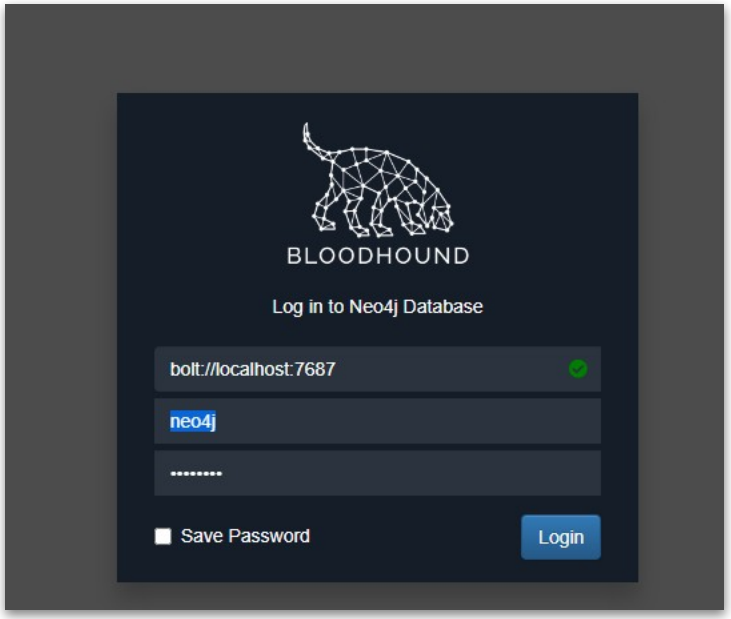
- You need to create a new database. Select **Create Database** and give it **bloodhound** as a name;
- On the right pane you should reset your **neo4j** password.



BloodHound – Neo4J

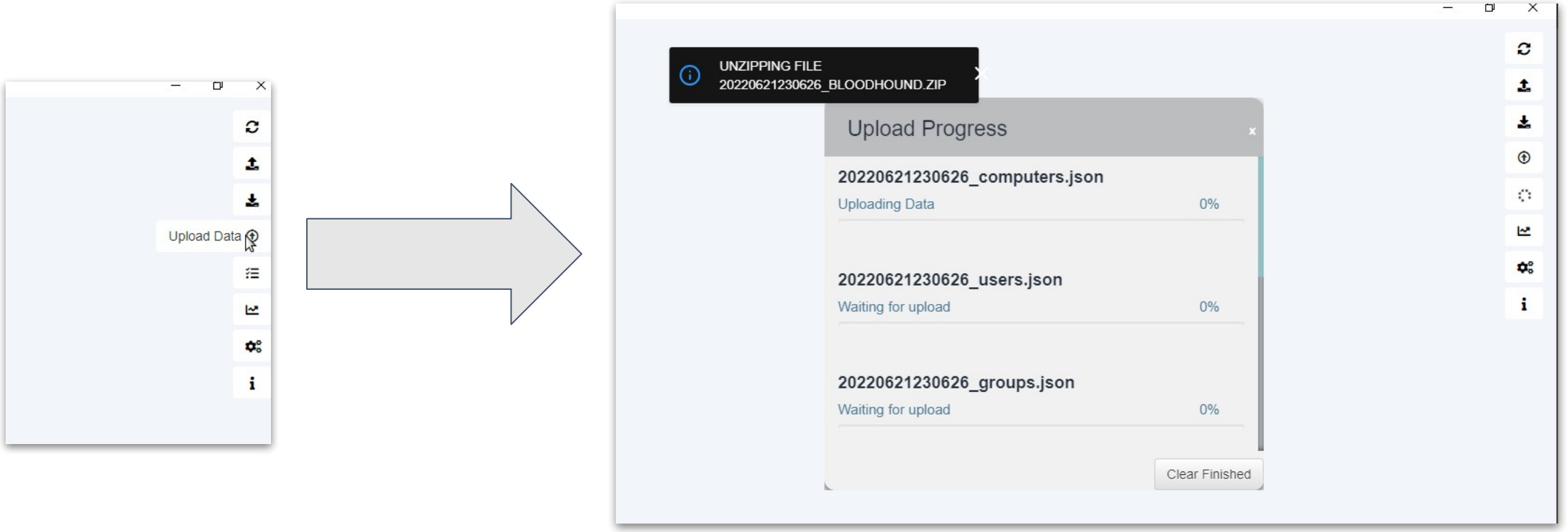
- You are all set!

Run **BloodHound** (not the collector) and use **neo4j** as user and whatever you set for password as a login.



BloodHound – Neo4J

- After you login, upload your ZIP file to the interface.

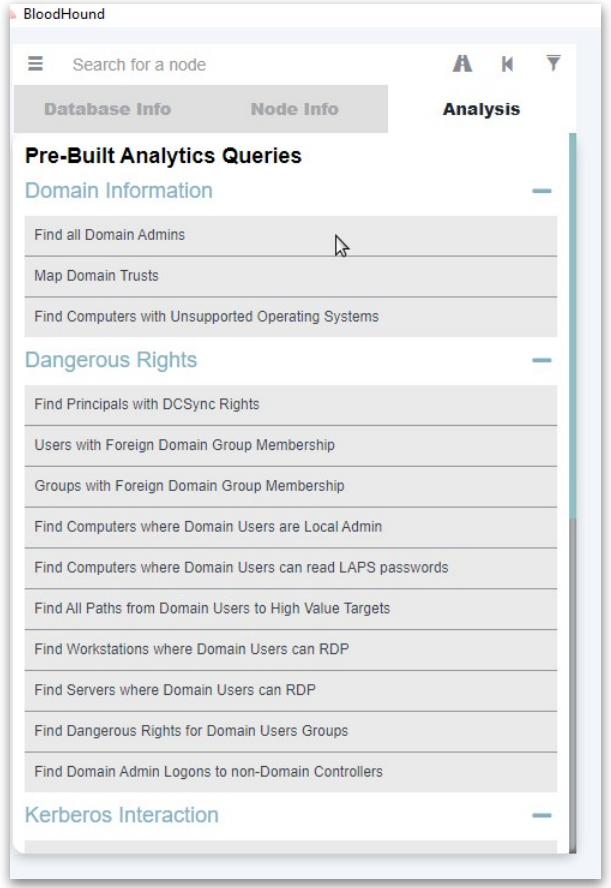


BloodHound – Querying

- **BloodHound** comes with a set of queries that you can perform;
- Queries will try to trace a path from one node (user/computer,…) to another;
- Depending on the account you perform the collection you might need to redo it if you get a new privileged account;
- You can also mark values as a High Value Target and if the target was already compromised:
    - This will help querying the interface and get a view on the environment itself.

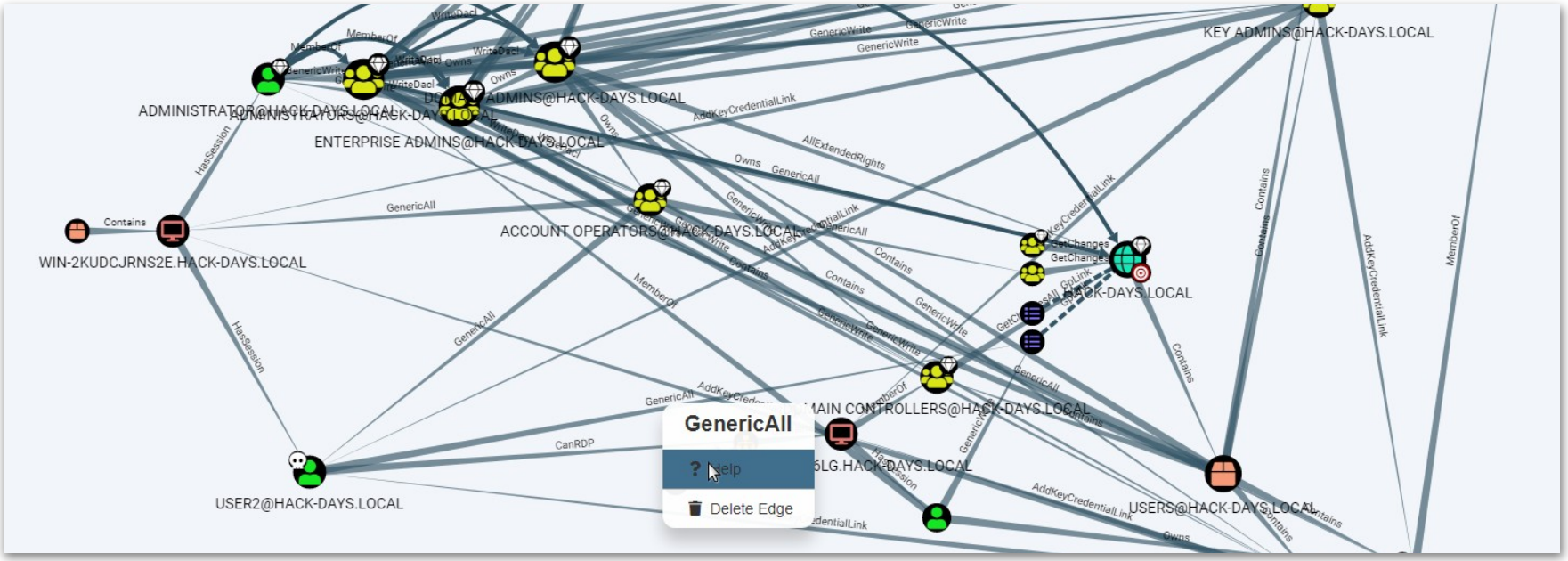
BloodHound – Querying

- You can also add new queries:
  - https://github.com/CompassSecurity/BloodHoundQueries
    ;
  - Create your own query by editing the Raw query (Future Work).

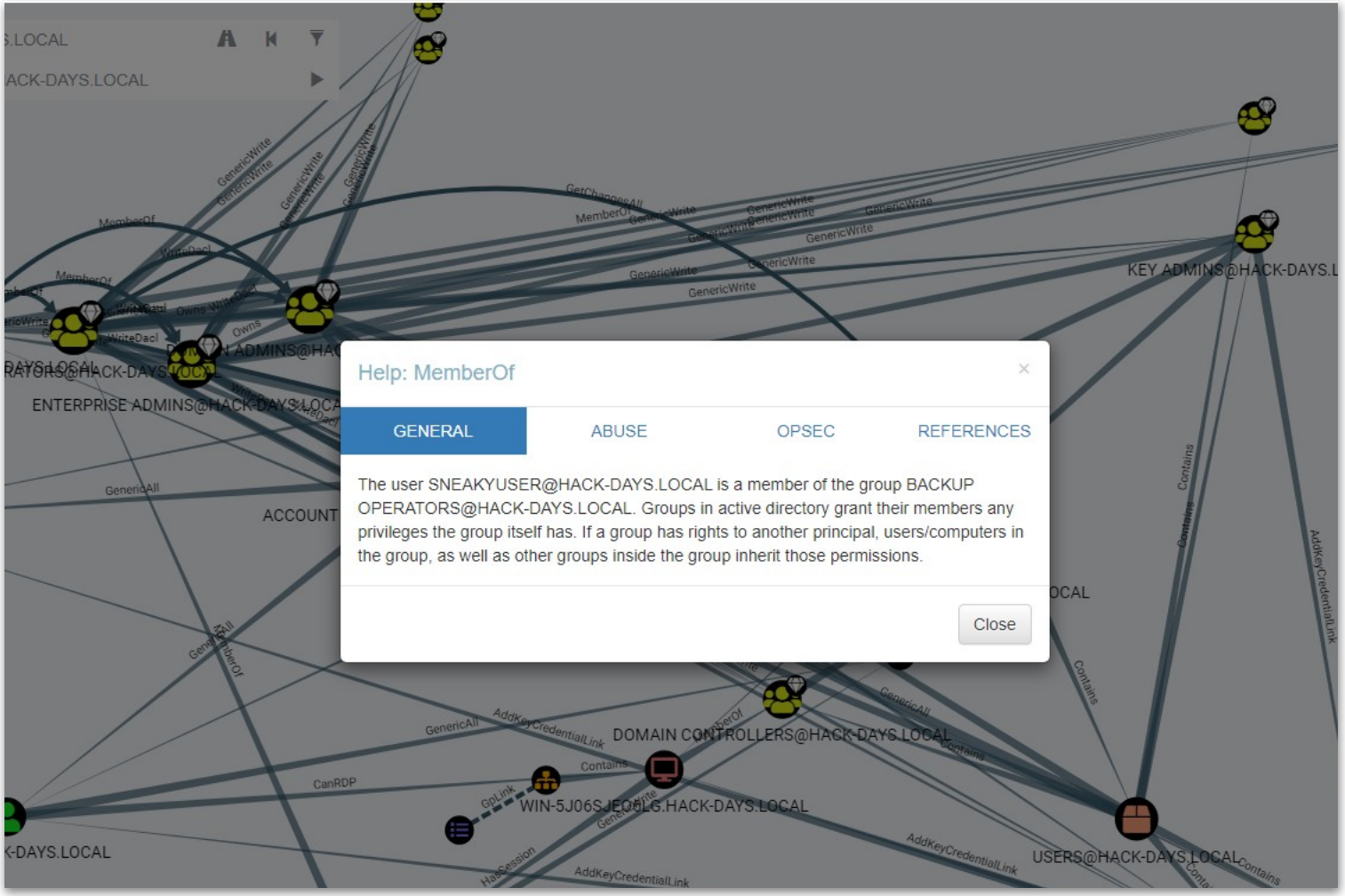


BloodHound – Analyzing the results

- You can navigate in the nodes;
- If you need help you can right-click and see an example of exploitation:
  - Sometimes you need preconditions for something to happen that you find impossible (i.e. machine disconnected).



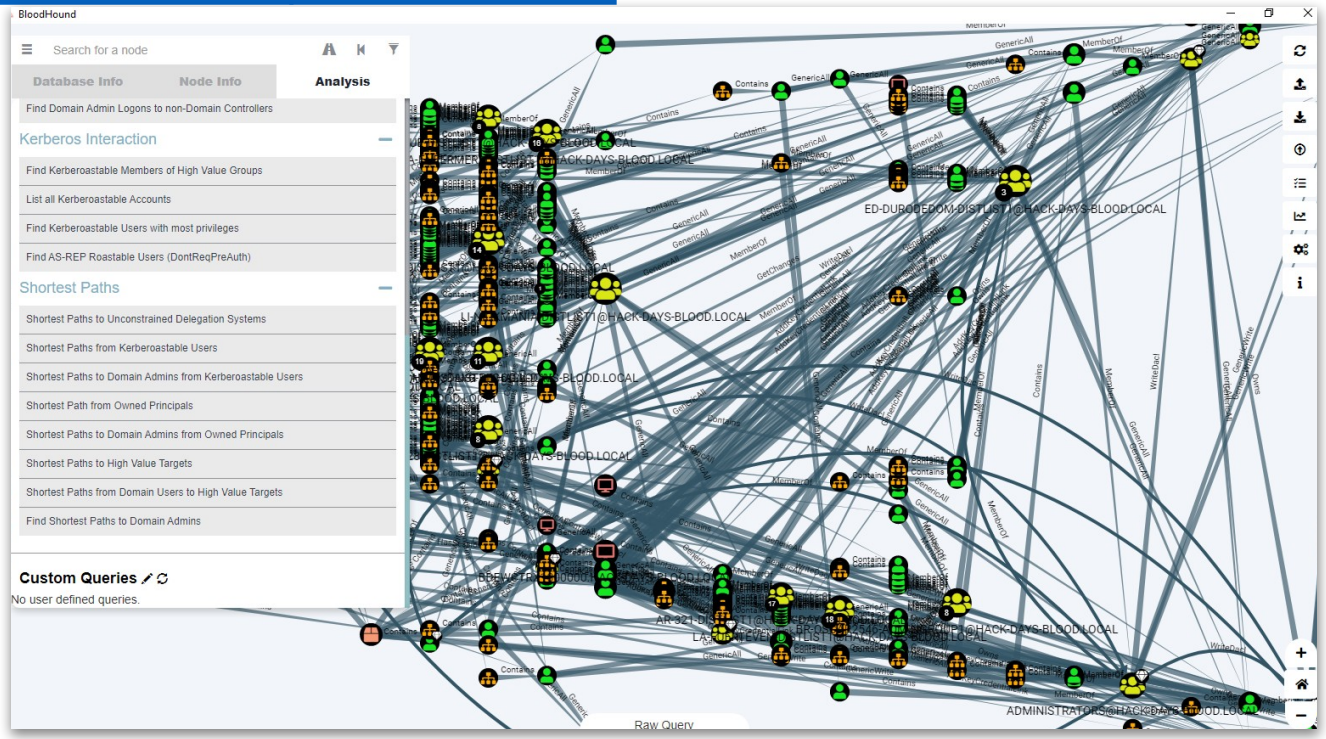
BloodHound – Analyzing the results



BloodHound – Need more to test?

This was a small exercise, do you need more data? We can use **BadBlood** to provision a DC and redo everything and check paths of exploitation.

BadBlood - https://github.com/davidprowe/BadBlood



Example of attacks - Nested Groups

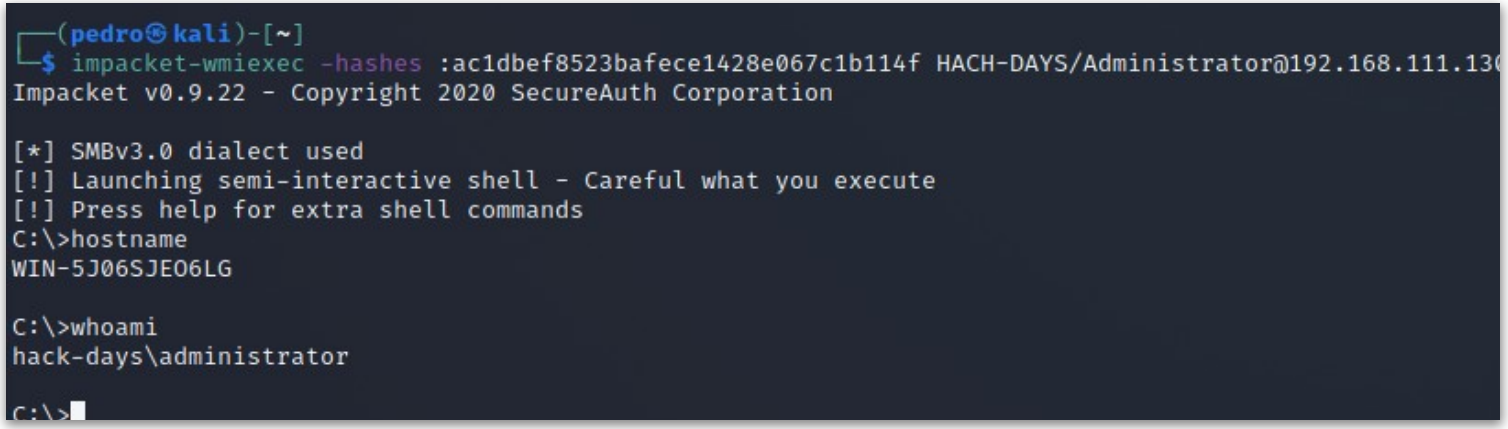
- Groups can have:
  - **Users**;
  - **Other groups**;
  - **Computers**.
- Often people look at the direct association in a group;
- In case a group contains another group that contains a different group (2nd order nested group) permissions can be overlooked.
- You must search recursively the group members to understand who have **the effective privileges**.

Example of attacks - Pass the Hash

- When dealing with Active Directory we must understand that **passwords are often optional** (Remember Mimikatz?);
- When we are authenticating before a service, Windows try to use the NTLM hash, to avoid passing clear-text credentials;
- The same hash can be replayed, authenticating the principal;
- This is known as **pass the hash**. If we, by dumping the LSASS process, get password hashes, we can use them for authentication, forgoing the need of brute forcing the password all by itself;
- We can also use password spraying to see if any account uses the same hash as authentication. This might come in handy if the Local Administrator account password is the same as a privileged one in the Active Directory.

Example of attacks - Pass the Hash

- Note, Mimikatz is also capable of doing this, we presented impacket just because of its simplicity.



Example of attacks – Constrained Delegations

- To interconnect services, sometimes its needed to give permissions on a service to impersonate users;
- This is made to allow principles to impersonate the user they are acting on behalf of;
- However, if such account is compromised, then we can use them to generate a ticket and impersonate the user IF the user does not have the "**This account is sensitive and cannot be delegated**" flag;
- This will grant a ticket of a user to connect to the service itself (constrained) or to anywhere (unconstrained);
- This attack requires specific configurations on the computer to be able to be trusted for delegation.
- If a user as write permissions on a computer object. He can set the Active Directory property **AllowToActOnBehalfOf** of a user and use that user to generate a valid ticket to connect as a different user to that resource.

Example of attacks - Active Directory Certificates Service (ADCS) Misconfigurations

- Some Windows environments have a service known as **Active Directory Certificates Services**;
- This service aims to expedite the requesting and emission of valid certificates, similar to an **internal Certificate Authority;**
- However if misconfigured, you can trick the service into providing a certificate with the template's owner authority and use it to authenticate before a service, impersonating it.

Example of attacks - Golden Tickets

- If you have the holy grail of having the **krbtgt** hash you can emit tickets not only for any principal;
- Therefore you can create a valid **ticket** for a domain administrator with an abusive expiration date and even, if the user changes passwords, you still have a valid authentication to the environment.

Example of attacks - DCSync

- If you have the following rights on the domain, you can perform **DCSync**:
  - Replicating Directory Changes;
  - Replicating Directory Changes All;
  - Replicating Directory Changes In Filtered Set;
- **DCSync** is the name given to the synchronization process between the Dcs;
- A malicious user can use these rights to “impersonate” a domain controller and it will receive a copy of the Active Directory itself;
- This will grant the attackers with all the users’ information including the users’ hash;
- The attacker can later use the **krbtgt** hash to create tickets to impersonate ANY user.

Good References

- https://adsecurity.org - Active Directory Security
- https://book.hacktricks.xyz/ - HackTricks
- https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Active%20Directory%20Attack.md
  - Active Directory Attacks
- https://www.pentesteracademy.com/activedirectorylab - Pentester Academy